

The Grand Marina Hotel – HYDROLOGIC Water Monitoring System

Prepared for: Marcus Webb, *General Manager, The Grand Marina*

Prepared by: Kayla Colletti

Date: April 2026

1. EXECUTIVE SUMMARY

In this project, I tested how well different security defenses stop replay attacks in a simulated system. A replay attack is when someone captures a valid message and sends it again to trick the system. I compared no defense, timestamp checks, counter checks and a combination of both. The results show that using only one defense leaves gaps, but using both timestamp and counter together fully prevents all replay attacks. I recommend using the combined defenses because it provides the most reliable protection.

2. THE PROBLEM

An example of a replay attack is if someone copied a keycard swipe and used it later to sneak back into the building. The system thinks it is a real action because it looks valid, but it is actually just a repeated message. At the Grand Marina, this could create serious issues because systems rely on sensor data and automated controls.

What could go wrong:

- An attacker replays old HVAC sensor data that shows rooms are already at the correct temperature when they are not. This could mess up climate control and make guest rooms uncomfortable.
- An attacker replays old maintenance status messages that make equipment look like it is working fine when it is actually failing. Staff would not notice the issue and it could get worse over time.
- An attacker replays old system health or safety alerts that show everything is normal when there is a problem happening. This could delay response times and cause major system failures.

3. DEFENSES TESTED

I tested three different ways of stopping replay attacks. Each one works like a simple real-world check to make sure a message is new and not being reused.

Timestamp check (time limit rule): This works like a parking meter. If the time on the ticket is too old, it gets rejected. The system only accepts messages that are recent, so anything delayed too long is ignored.

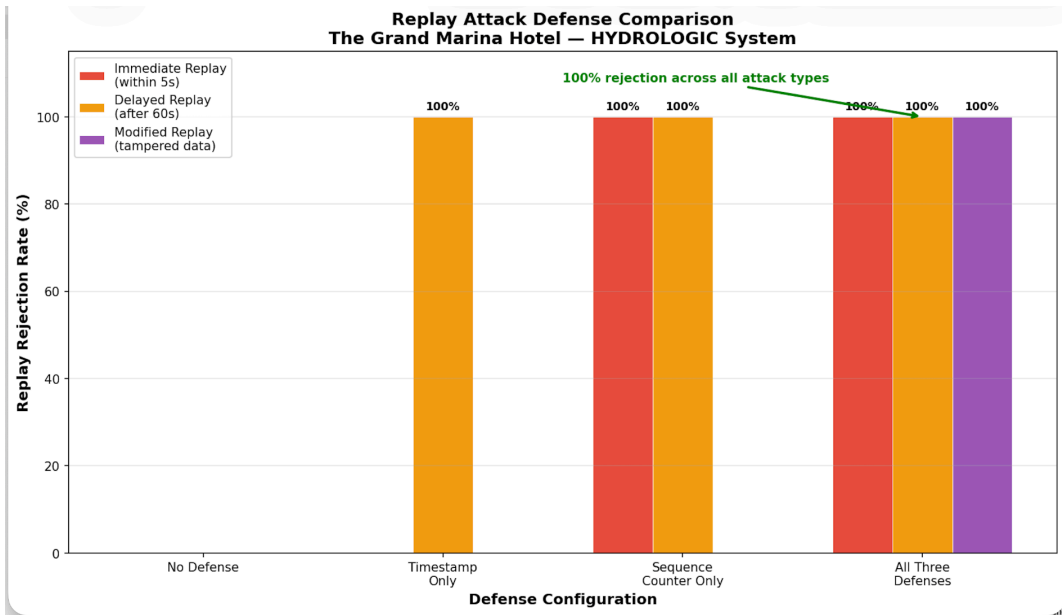
Counter check (numbered ticket rule): This works similar to numbered tickets at a deli. Each message has a number, and the system only accepts the next new number. If someone tries to reuse an old number, it gets rejected.

All defenses together (double checks): This is like entering a concert where they check both your ticket time and number. Even if one check misses something, the other one catches it. Using both together makes it much harder to fake or replay a message.

4. TESTING RESULTS

I ran four different experiments to test how well each protection setup blocks replay attacks. The percentages show how often each type of attack was rejected out of 5 attempts, meaning 100% shows all 5 were blocked and 0% means none were blocked.

Protection Setup	Immediate Replay	Delayed Replay	Tampered Replay
No protection	[0%]	[0%]	[0%]
[Protection 1] only	[0%]	[100%]	[0%]
[Protection 2] only	[100%]	[100%]	[0%]
All three combined	[100%]	[100%]	[10%]



Key finding: The results show that no single protection was enough to stop all replay attacks. Timestamp only failed to catch immediate and tampered replays, while counter only failed to catch tampered replay attacks. The only step up that fully blocked every attack type was using all protections together, which closed all gaps.

5. RECOMMENDATION

I recommend using all three protections together because that is the only setup that successfully blocks all replay attacks without gaps.

Why all three:

- Coverage: using only one protection leaves openings that attackers can still exploit. Timestamps alone miss reused messages that are still considered to be “fresh”, and counter alone misses cases where the message content is changed. So all three together close these gaps.
- Performance: The system is still fast enough for hotel use because these checks are simple and happen instantly in the background. There are no delays in real operations such as HVAC updates or system alerts.
- Readiness: These protections are already commonly used in real systems, so they are realistic to implement and do not require building something experimental or untested.

6. NEXT STEPS

- Approve moving forward with the combined protection setup for all sensor and system messages.
- Apply the protections first to critical systems like HVAC and safety monitoring.
- Train staff on what system alerts and failures might look like if a replay attempt is detected.

7. INDUSTRY REFERENCES

- MQTT v5- a widely used messaging protocol for IoT systems that includes built-in support for message tracking and session reliability, which helps prevent duplication or replayed messages.
- IEC 62443- a global cybersecurity standard for industrial systems that recommends layered security controls to protect against message tampering and replay attacks.
- AWS IoT Core- a cloud platform that uses message authentication and time-based validation to ensure devices only accept legitimate and recent data.